

Relazione di Network Scanning e Vulnerability Assessment

Target: Metasploitable (10.0.2.3) — Strumenti: Nmap 7.99, Nessus Essentials

Data esercitazione: 09 luglio 2026

1. Obiettivo dell'esercitazione

L'obiettivo dell'esercitazione è stato quello di condurre una attività di ricognizione e valutazione della sicurezza su una macchina target volutamente vulnerabile (Metasploitable), operando da una macchina di attacco basata su Kali Linux. Il lavoro si è articolato in due fasi principali: una fase di network scanning con Nmap, finalizzata a identificare l'host attivo, le porte aperte e i servizi in ascolto con le relative versioni, e una fase di vulnerability assessment con Nessus Essentials, finalizzata a individuare le vulnerabilità note associate ai servizi rilevati.

2. Ambiente e metodologia

L'esercitazione è stata svolta in un ambiente di laboratorio virtualizzato (Oracle VirtualBox), con le due macchine collegate sulla stessa rete interna:

- Macchina attaccante: Kali Linux, con Nmap 7.99 e Nessus Essentials installati.
- Macchina target: Metasploitable, con indirizzo IP 10.0.2.3 e indirizzo MAC 08:00:27:85:96:50 (interfaccia virtuale Oracle VirtualBox).

La metodologia seguita ricalca le fasi classiche di un penetration test in ambiente controllato: individuazione dell'host attivo (host discovery), scansione delle porte (port scanning), identificazione dei servizi e delle relative versioni (service/version detection) e, infine, scansione delle vulnerabilità tramite un vulnerability scanner automatico.

3. Fase 1 – Identificazione dell'host attivo

Il primo passo è consistito nel verificare la raggiungibilità e lo stato dell'host target. Un test di ping (3 pacchetti trasmessi, 3 ricevuti, 0% di perdita, RTT medio di circa 1,1 ms) ha confermato che l'host 10.0.2.3 era attivo e raggiungibile sulla rete. Successivamente è stato eseguito un primo scan di rilevamento host con Nmap, che ha confermato lo stato "up" dell'host e ne ha restituito l'indirizzo MAC (08:00:27:85:96:50), riconducibile a un'interfaccia di rete virtuale Oracle VirtualBox.

4. Fase 2 – Port scanning

Per individuare le porte aperte sull'host target è stata eseguita una scansione SYN (nmap -sS 10.0.2.3), lanciata con privilegi di amministratore (sudo). La scansione ha analizzato le 1000 porte più comuni, rilevando 977 porte chiuse e 23 porte aperte. Questo tipo di scansione, essendo basata sull'invio di soli pacchetti SYN, è relativamente rapida (circa 1,2 secondi) e permette di mappare in modo furtivo i servizi esposti dall'host senza completare l'handshake TCP a tre vie.

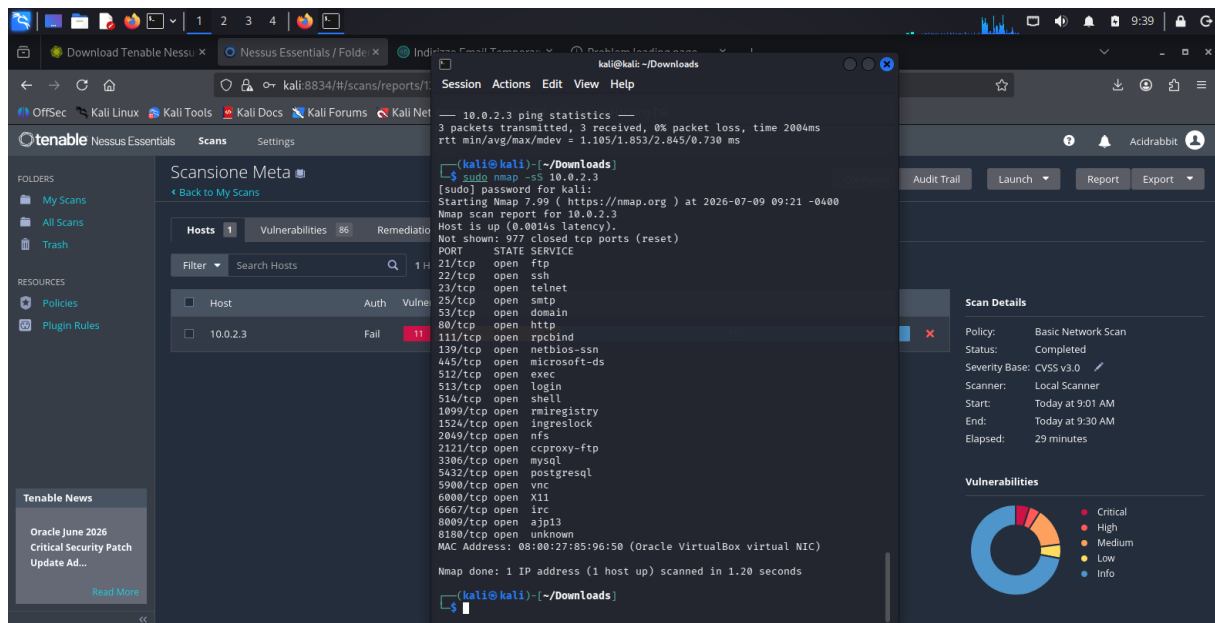


Fig. 1 – Output del comando "sudo nmap -sS 10.0.2.3": 23 porte TCP aperte su 10.0.2.3.

5. Fase 3 – Rilevamento di servizi e versioni

Per approfondire l'analisi, è stata eseguita una seconda scansione con l'opzione di service/version detection (nmap -sV 10.0.2.3). Questa modalità invia sonde specifiche ai servizi individuati per determinarne non solo il nome ma anche la versione esatta del software in ascolto, informazione fondamentale per la successiva ricerca di vulnerabilità note. La scansione, durata circa 12,7 secondi, ha confermato le 23 porte aperte già individuate nella fase precedente, arricchendo il risultato con il dettaglio del prodotto e della versione di ciascun servizio.

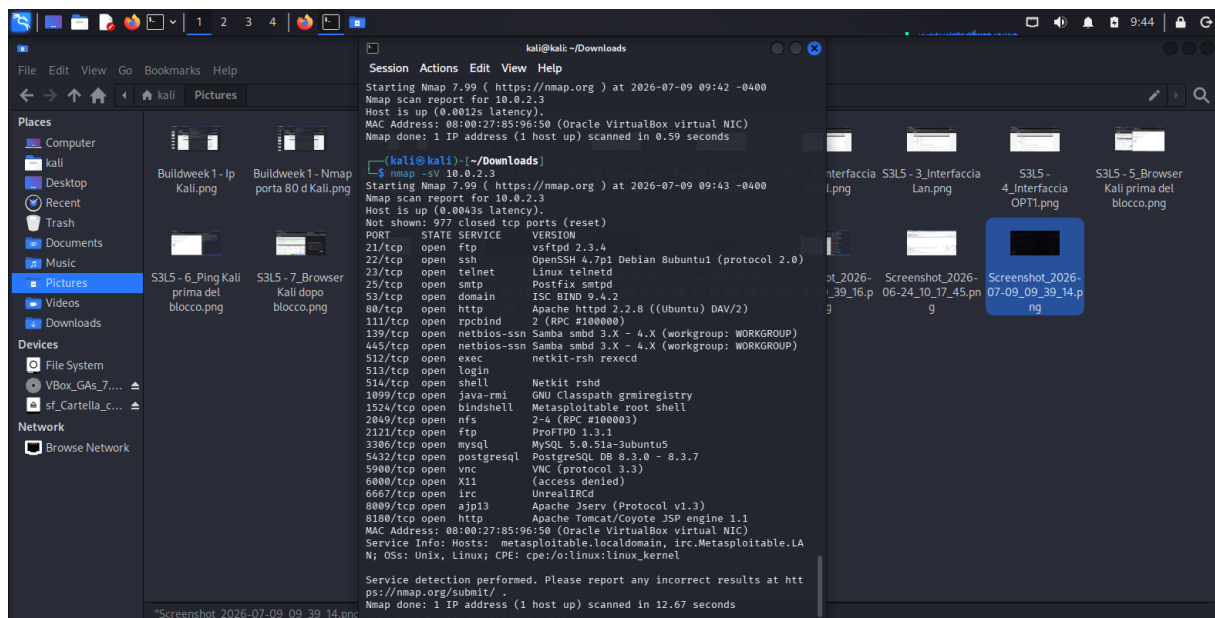


Fig. 2 – Output del comando "nmap -sV 10.0.2.3": servizi e versioni rilevati sull'host target.

La tabella seguente riassume i servizi individuati con la relativa versione:

Porta/Proto	Servizio	Versione rilevata
21/tcp	ftp	vsftpd 2.3.4

Porta/Proto	Servizio	Versione rilevata
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	telnet	Linux telnetd
25/tcp	smtp	Postfix smtpd
53/tcp	domain	ISC BIND 9.4.2
80/tcp	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	rpcbind	2 (RPC #100000)
139/tcp	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp	exec	netkit-rsh rexecd
513/tcp	login	-
514/tcp	shell	Netkit rshd
1099/tcp	java-rmi	GNU Classpath grmiregistry
1524/tcp	bindshell	Metasploitable root shell
2049/tcp	nfs	2-4 (RPC #100003)
2121/tcp	ftp	ProFTPD 1.3.1
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	vnc	VNC (protocol 3.3)
6000/tcp	X11	(access denied)
6667/tcp	irc	UnrealIRCd
8009/tcp	ajp13	Apache Jserv (Protocol v1.3)
8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1

Dall'analisi dei risultati emerge un profilo di sistema estremamente datato e volutamente esposto: sono presenti servizi obsoleti e notoriamente vulnerabili come vsftpd 2.3.4 (nota per una backdoor), UnrealIRCd (anch'esso associato a una backdoor storica), telnet e rsh/rlogin (protocolli in chiaro), oltre a un servizio in ascolto sulla porta 1524 esplicitamente identificato come "Metasploitable root shell", segno di un accesso privilegiato già disponibile senza autenticazione.

6. Fase 4 – Vulnerability Assessment con Nessus Essentials

Con le informazioni raccolte tramite Nmap come base, è stata configurata ed eseguita una scansione di vulnerability assessment con Nessus Essentials, utilizzando la policy "Basic Network Scan" e la classificazione di severità basata su CVSS v3.0. La scansione, denominata "Scansione Meta", ha impiegato 29 minuti (dalle 09:01 alle 09:30) e ha analizzato l'host 10.0.2.3, per il quale l'autenticazione non è stata configurata (scansione condotta in modalità non autenticata, "Auth: Fail").

Parametro	Valore
Target	10.0.2.3
Indirizzo MAC	08:00:27:85:96:50 (Oracle VirtualBox virtual NIC)

Parametro	Valore
Sistema operativo rilevato	Linux Kernel 2.6 su Ubuntu 8.04 (hardy)
Policy utilizzata	Basic Network Scan
Scanner	Local Scanner
Base di severità	CVSS v3.0
Autenticazione	Fail (scansione non autenticata)
Inizio scansione	09:01
Fine scansione	09:30
Durata	29 minuti
Vulnerabilità rilevate	86 totali

Al termine della scansione, Nessus ha rilevato complessivamente 86 vulnerabilità sull'host, distribuite su più livelli di severità (Critical, High, Medium, Low, Info), come mostrato nel grafico a ciambella dei risultati e nel dettaglio dell'host.

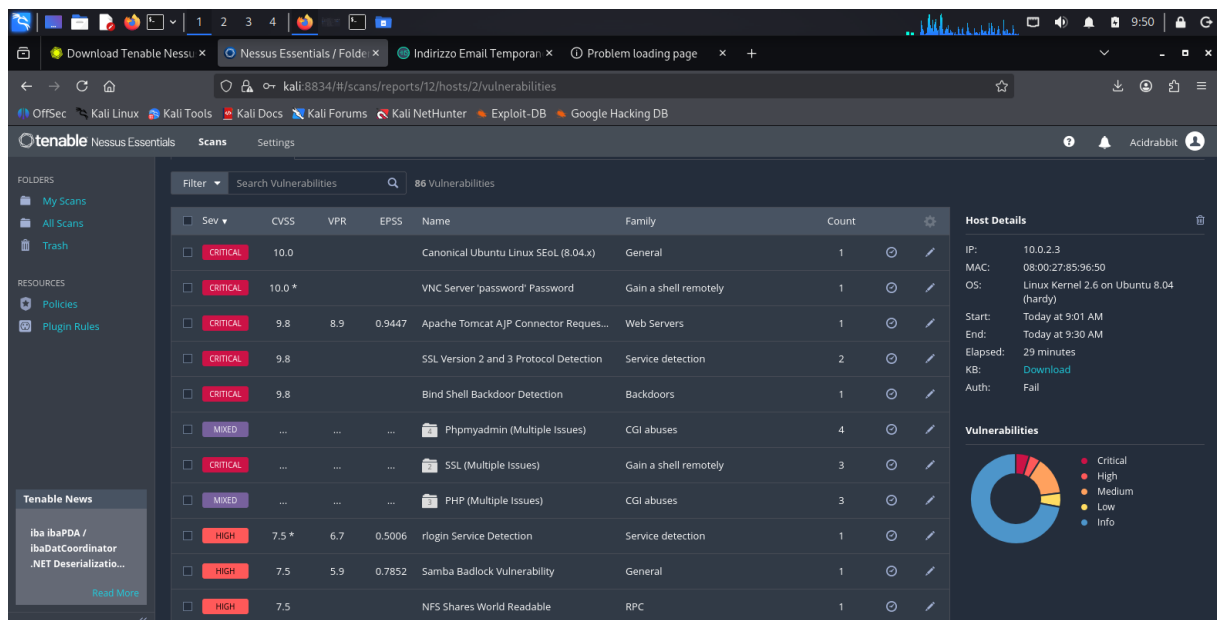


Fig. 3 – Elenco delle vulnerabilità rilevate da Nessus Essentials sull'host 10.0.2.3 (86 vulnerabilità totali).

7. Analisi delle vulnerabilità principali

Tra le 86 vulnerabilità individuate, le più rilevanti per severità e impatto potenziale sono riportate nella tabella seguente:

Severità	CVSS	Nome vulnerabilità	Famiglia
Critical	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	General
Critical	10.0*	VNC Server 'password' Password	Gain a shell remotely
Critical	9.8	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers
Critical	9.8	SSL Version 2 and 3 Protocol Detection	Service detection
Critical	9.8	Bind Shell Backdoor Detection	Backdoors

Severità	CVSS	Nome vulnerabilità	Famiglia
Critical	-	SSL (Multiple Issues)	Gain a shell remotely
Mixed	-	Phpmyadmin (Multiple Issues)	CGI abuses
Mixed	-	PHP (Multiple Issues)	CGI abuses
High	7.5*	rlogin Service Detection	Service detection
High	7.5	Samba Badlock Vulnerability	General
High	7.5	NFS Shares World Readable	RPC

7.1 Vulnerabilità critiche di maggior rilievo

- Canonical Ubuntu Linux SEoL (8.04.x) – CVSS 10.0: il sistema operativo target ha raggiunto la fine del ciclo di vita (End of Life) e non riceve più aggiornamenti di sicurezza, esponendo l'host a qualunque vulnerabilità scoperta successivamente al termine del supporto.
- VNC Server 'password' Password – CVSS 10.0: il servizio VNC (porta 5900) risulta protetto da una password debole/di default, consentendo un accesso remoto non autorizzato alla shell grafica del sistema.
- Apache Tomcat AJP Connector Request Injection ("Ghostcat") – CVSS 9.8: la vulnerabilità nel connettore AJP di Apache Tomcat (porta 8009) permette la lettura di file arbitrari e, in determinate condizioni, l'esecuzione di codice remoto.
- Bind Shell Backdoor Detection – CVSS 9.8: coerentemente con quanto osservato con Nmap sulla porta 1524, Nessus conferma la presenza di una shell di root accessibile senza autenticazione.
- SSL Version 2 and 3 Protocol Detection – CVSS 9.8: i servizi che espongono ancora SSLv2/SSLv3 sono vulnerabili a downgrade e attacchi noti (es. POODLE), poiché tali protocolli sono considerati crittograficamente insicuri e deprecati.

7.2 Altre vulnerabilità di rilievo

- Phpmyadmin (Multiple Issues) e PHP (Multiple Issues) – severità mista: molteplici problematiche note legate a versioni obsolete di PHP e phpMyAdmin, spesso sfruttabili per esecuzione di codice remoto o accesso non autorizzato al database.
- rlogin Service Detection – CVSS 7.5: il servizio rlogin, basato su autenticazione debole (host-based trust), consente potenzialmente accessi non autorizzati.
- Samba Badlock Vulnerability – CVSS 7.5: vulnerabilità nel protocollo SMB/Samba che può compromettere la riservatezza e l'integrità delle comunicazioni di rete.
- NFS Shares World Readable – CVSS 7.5: le condivisioni NFS risultano leggibili da qualunque utente della rete, con possibile esposizione di dati sensibili.

8. Conclusioni

L'esercitazione ha permesso di applicare in modo pratico il flusso di lavoro tipico di una fase di ricognizione e assessment in un penetration test: dall'identificazione dell'host attivo, al port scanning, fino alla caratterizzazione dei servizi e alla ricerca automatizzata delle vulnerabilità. I risultati ottenuti su Metasploitable confermano il ruolo di questa macchina come ambiente didattico volutamente vulnerabile: la presenza di servizi obsoleti, backdoor note, protocolli in chiaro e credenziali deboli genera un numero elevato di vulnerabilità critiche e ad alta severità (86 in totale), utili per comprendere concretamente l'impatto di configurazioni di sicurezza inadeguate.

In un contesto reale, le contromisure principali suggerite dai risultati sarebbero: l'aggiornamento o la dismissione del sistema operativo obsoleto, la disattivazione dei servizi non necessari (telnet, rsh/rlogin, bindshell), l'applicazione di patch ai servizi vulnerabili (Tomcat, Samba, phpMyAdmin/PHP), la disabilitazione dei protocolli SSL obsoleti a favore di TLS aggiornato, l'impostazione di credenziali robuste per i servizi di accesso remoto (VNC, SSH) e la restrizione delle condivisioni NFS ai soli utenti autorizzati.

9. Mitigazione delle vulnerabilità critiche

Di seguito sono riportate, per ciascuna delle vulnerabilità critiche individuate, le azioni di remediation raccomandate. Trattandosi di Metasploitable, una macchina volutamente obsoleta e priva di patch, la mitigazione "reale" corrisponderebbe in molti casi alla sostituzione dei componenti; le indicazioni sono comunque riportate come si applicherebbero a un sistema in produzione.

9.1 Canonical Ubuntu Linux SEoL (8.04.x) – CVSS 10.0

Il sistema operativo non riceve più patch di sicurezza dal vendor.

- Eseguire l'upgrade a una release Ubuntu LTS ancora supportata (es. 22.04 o 24.04 LTS), pianificando un percorso di migrazione dati/applicazioni.
- Se l'upgrade non è immediatamente possibile, isolare l'host in una rete segregata (VLAN dedicata) senza accesso diretto da Internet, in attesa della dismissione.
- Attivare un piano di patch management continuo per evitare che si ripresenti la stessa situazione in futuro.

9.2 VNC Server con password debole – CVSS 10.0

Il servizio VNC sulla porta 5900 è protetto da una password debole/di default.

- Impostare una password complessa e univoca per l'accesso VNC, oppure disabilitare l'autenticazione a sola password a favore di meccanismi più robusti (tunneling SSH, VPN).
- Non esporre la porta 5900 direttamente su reti non fidate: limitarne l'accesso tramite firewall alle sole postazioni amministrative autorizzate.
- Valutare l'uso di VNC solo all'interno di un tunnel cifrato (es. SSH port forwarding) invece che in chiaro.

9.3 Apache Tomcat AJP Connector Request Injection – "Ghostcat" (CVE-2020-1938) – CVSS 9.8

Il connettore AJP di Tomcat sulla porta 8009 consente lettura di file arbitrari e potenziale esecuzione di codice remoto.

- Aggiornare Apache Tomcat a una versione patchata (successiva a 9.0.31 / 8.5.51 / 7.0.100, a seconda del ramo).
- Se il connettore AJP non è necessario, disabilitarlo completamente nel file server.xml.
- Se è necessario, vincolarne l'ascolto alla sola interfaccia locale (127.0.0.1) e impostare l'attributo "requiredSecret" per l'autenticazione tra Tomcat e il web server front-end.

9.4 Bind Shell Backdoor / vsftpd 2.3.4 backdoor (CVE-2011-2523) – CVSS 9.8

La porta 1524 espone una shell di root senza autenticazione, tipicamente associata alla backdoor storica di vsftpd 2.3.4.

- Rimuovere immediatamente il binario vsftpd 2.3.4 compromesso e sostituirlo con una versione ufficiale e aggiornata del pacchetto.
- Verificare l'integrità del sistema (file di sistema, utenti, crontab) poiché la presenza di una backdoor attiva indica un sistema potenzialmente già compromesso.
- Bloccare a livello di firewall qualunque porta non esplicitamente richiesta da un servizio legittimo (es. 1524/tcp).

9.5 SSL Version 2 e 3 Protocol Detection – CVSS 9.8

Diversi servizi espongono ancora i protocolli SSLv2/SSLv3, vulnerabili a downgrade e attacchi noti (es. POODLE).

- Disabilitare esplicitamente SSLv2 e SSLv3 nella configurazione di ciascun servizio (Apache, Postfix, ecc.), abilitando esclusivamente TLS 1.2 o superiore.
- Aggiornare le librerie crittografiche (OpenSSL) e i servizi che le utilizzano.
- Eseguire periodicamente scansioni di verifica della configurazione TLS (es. con testssl.sh o Nessus) dopo ogni intervento.

9.6 UnrealIRCd Backdoor (CVE-2010-2075)

Il servizio IRC sulla porta 6667 corrisponde a una versione di UnrealIRCd nota per contenere una backdoor nel codice sorgente distribuito.

- Reinstallare UnrealIRCd da una fonte ufficiale e verificata, controllando i checksum dei pacchetti scaricati.
- Aggiornare alla versione più recente del software e rimuovere il servizio se non strettamente necessario.

9.7 Samba Badlock Vulnerability (CVE-2016-2118) – CVSS 7.5

Il servizio Samba (porte 139/445) è vulnerabile a Badlock, che può compromettere la riservatezza e l'integrità del canale SMB.

- Aggiornare Samba a una versione che includa la patch per Badlock (Samba 4.4.2/4.3.8/4.2.11 o successive).
- Forzare la firma dei pacchetti SMB (SMB signing) e disabilitare SMBv1 in favore di versioni più recenti del protocollo.

9.8 NFS Shares World Readable – CVSS 7.5

Le condivisioni NFS (porta 2049) risultano accessibili in lettura da qualunque host della rete.

- Restringere l'export NFS ai soli indirizzi IP o subnet autorizzati tramite il file `/etc/exports`, utilizzando le opzioni di controllo accessi appropriate.
- Applicare permessi a livello di file system che limitino la lettura ai soli utenti autorizzati, e valutare l'uso di NFSv4 con Kerberos per l'autenticazione.

9.9 Phpmyadmin e PHP (Multiple Issues) – severità mista

Le versioni obsolete di PHP e phpMyAdmin espongono a molteplici vulnerabilità note, alcune sfruttabili per esecuzione di codice remoto.

- Aggiornare PHP e phpMyAdmin alle versioni stabili più recenti supportate dal vendor.

- Limitare l'accesso a phpMyAdmin tramite autenticazione aggiuntiva (es. HTTP Basic Auth, restrizione per IP) e rimuoverlo se non necessario in produzione.

9.10 Priorità di intervento

In un contesto reale, data la severità e la facilità di sfruttamento, l'ordine di intervento consigliato sarebbe: (1) rimozione della backdoor attiva sulla porta 1524 e verifica di compromissione del sistema; (2) messa in sicurezza o dismissione del sistema operativo EoL; (3) patching di Tomcat (Ghostcat) e Samba (Badlock); (4) hardening di VNC e disabilitazione di SSLv2/v3; (5) messa in sicurezza di NFS, phpMyAdmin e PHP. Questo ordine riflette la combinazione di impatto potenziale (accesso root, esecuzione di codice remoto) e facilità di sfruttamento da parte di un attaccante non autenticato.